

agent: discovery-security-agent cli: Claude Code CLI llm: claude-opus-4-8 run_id: 20260807T165658_j4iyle generated_at: 2026-08-07T12:23:31.178Z

6. Security Hotspots Analysis

Objective: Address key OWASP-class security vulnerabilities and dependency risk.

Date: 2026-08-07 12:25:57 UTC | **Scope:** shende-shweta/pingcrm (branch master) — Laravel 11 / PHP 8.2 backend + React 19 + Inertia.js (TypeScript) frontend, SQLite/MySQL via Eloquent, session-cookie auth (Laravel Sanctum installed)

Executive Summary

EXECUTIVE SUMMARY

This review covered **both layers**: the PHP/Laravel backend (141 source files) and the React/Inertia TypeScript frontend (904 files). The posture is **High Risk**, driven by an extensive "Legacy IVR" subsystem that was grafted onto an otherwise-idiomatic PingCRM base. The most severe issues are **unauthenticated SQL injection** — 80 IVR controllers build `SELECT ... LIKE '%" . $q . "%'` strings directly from request input and 12 legacy repositories run 480 hand-concatenated `DB::select($sql)` queries — reachable through 80 `ivr-legacy/*` API routes that carry no `auth` middleware and accept **GET** for state-changing `store` `update` `destroy` `import` `sync` actions. On top of that, **4,400 controller endpoints** call `extract($request->all())`, injecting attacker-controlled keys straight into local scope and then into `insertGetId((array) $payload)` (mass assignment). Every legacy controller hard-codes `tenantId = 1`, collapsing multi-tenant isolation, and 12 "God services" embed hard-coded API keys (`LEGACY_IVR_KEY_*`). Frontend risk is narrower but real: `Shared/Pagination.tsx` renders server-supplied labels through `dangerouslySetInnerHTML`. Dependency hygiene is mixed — `roave/security-advisories` guards Composer, but there is no `composer audit` / `npm audit` / Dependabot step in CI, and the npm tree pins EOL majors (`react-router-dom` 5.2.0, ESLint 8, Prettier 2).

1,045

FILES SCANNED FOR INPUT HANDLING

5,134

CONCRETE INJECTION/XSS/CSRF/CORS/AUTH FINDINGS

4

DEPENDENCIES FLAGGED OUTDATED/EOL

8/10

OWASP CATEGORIES WITH FINDINGS

OVERALL CODEBASE RATING — SECURITY

High Risk

Unauthenticated SQL injection and mass-assignment on 80 CSRF-exempt IVR routes, plus broken tenant isolation, force a High Risk verdict.

6.1 Security Benchmark Ratings

One row per KPI. "Measured" is the real value found; "Rating" is the band it falls into. This table is the source for the Overall Codebase Rating banner above. Vulnerability density uses a conservative floor of distinct SQLi + XSS sinks (562) over ~177.7 KLOC source; including the 4,400 `extract()` mass-assignment endpoints it rises to ~29/KLOC.

#	Security KPI	Target	GOOD	MODERATE	HIGH RISK	Measured	Rating
H1	Critical Vulnerabilities	0	0	1	>1	≥2 (unauth SQLi; mass-assignment via <code>extract()</code>)	HIGH RISK
H2	High Vulnerabilities	0	<5	5–10	>10	>10 (broken access control, IDOR, GET state-change, hard-coded secrets)	HIGH RISK
H3	Medium Vulnerabilities	low	<20	20–50	>50	>50 (info-leak error swallowing, XSS sink, misconfig)	HIGH RISK
H4	Vulnerability Density	<0.5/KLOC	<0.5	0.5–1.0	>1.0	~3.2/KLOC (562 sinks); ~29/KLOC incl. <code>extract</code>	HIGH RISK
H5	OWASP Top 10 Compliance	>95%	>95%	80–95%	<80%	~20% clean (8/10 categories with findings)	HIGH RISK
H6	Critical/High Vulnerable Deps	0	0	1	>1	Unverified — no scanner; ≥1 suspected (EOL majors)	MODERATE
H7	Outdated Dependencies	<10%	<10%	10–25%	>25%	~12% (react-router-dom 5, ESLint 8, Prettier 2)	MODERATE
H8	End-of-Life Dependencies	0	0	1–5	>5	3 (react-router-dom 5.2.0, ESLint 8, Prettier 2.x)	MODERATE

6.2 Hotspot-by-Hotspot Evidence

SQL Injection — unparameterized query construction **CRITICAL**

Two distinct patterns build SQL by string concatenation from request input. **(1)** Every one of the 80 IVR controllers concatenates the `q` request parameter into a `LIKE` clause; **(2)** 12 legacy repositories build 480 `DB::select($sql)` statements the same way. The `(int)` cast on `tenant_id` is not applied to the user-controlled `$q` / `$filter`.

`app/Http/Controllers/Ivr/CallRecordingStoreController.php:27-30`

```
$q = $request->get("q");
if ($q) {
    $rows = DB::select("select * from ivr_call_recordings where name like
'%" . $q . "%' and tenant_id = " . $this->tenantId);
}
```

app/Repositories/Legacy/CallAnalyticsRepository.php:11-16

```
$sql = "SELECT * FROM ivr_call_analyticss WHERE tenant_id = " . (int)
$tenantId;
if ($filter) {
    $sql .= " AND name LIKE '%" . $filter . "%'"; // SQLi pattern for discovery
    bots
}
return DB::select($sql);
```

Exploit scenario: An attacker requests `GET /api/ivr-legacy/call-recording/store?`

`q=%25%27%20UNION%20SELECT%20email,password,3,4%20FROM%20users--%20-`. The `q` value breaks out of the `LIKE '%...%'` literal, appends a `UNION SELECT` against the `users` table, and the JSON branch (`$request->wantsJson()`) returns the credential rows directly in `{"data": [...]}`. No authentication is required (see Broken Access Control below).

Recommended fix:

1. Replace every `DB::select("..." . $var...)` with parameter bindings: `DB::select('... name LIKE ?', ['%' . $q . '%'])`, or preferably `CallRecording::where('name', 'like', '%' . $q . '%')` Eloquent scopes.
2. Refactor the 12 `app/Repositories/Legacy/*Repository.php` classes to accept bindings and stop concatenating `$filter`.
3. Add a `larastan` / `phpstan` rule or a CI grep gate that fails on `DB::select(" / ->whereRaw(` with concatenation.
4. Enforce tenant scoping via a global Eloquent scope instead of inline string concatenation.

80 files affected.

File	Line(s)	Issue	Action
app/Http/Controllers/Ivr/AgentDeskDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/AgentDeskExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/AgentDeskImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/AgentDeskIndexController.php	28	SQL built by string concatenation from	Replace with parameterized bindings or Eloquent query

		request/filter input (SQL injection)	builder; add tenant scope
app/Http/Controllers/Ivr/AgentDeskStoreController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/AgentDeskSyncController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/AgentDeskUpdateController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursIndexController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursStoreController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursSyncController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/BusinessHoursUpdateController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallAnalyticsDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallAnalyticsExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallAnalyticsImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallAnalyticsIndexController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope

app/Http/Controllers/Ivr/CallAnalyticsStoreController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallAnalyticsSyncController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallAnalyticsUpdateController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowIndexController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowStoreController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowSyncController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallFlowUpdateController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallRecordingDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallRecordingExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallRecordingImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallRecordingIndexController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/CallRecordingStoreController.php	28	SQL built by string concatenation from	Replace with parameterized bindings or Eloquent query builder; add tenant scope

		request/filter input (SQL injection)	
<code>app/Http/Controllers/Ivr/CallRecordingSyncController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRecordingUpdateController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingDestroyController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingExportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingImportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingIndexController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingStoreController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingSyncController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CallRoutingUpdateController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CustomerProfileIndexController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CustomerProfileStoreController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/CustomerProfileUpdateController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/DidInventoryDestroyController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/DidInventoryExportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope

<code>app/Http/Controllers/Ivr/DidInventoryImportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/DidInventoryIndexController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/DidInventoryStoreController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/DidInventorySyncController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/DidInventoryUpdateController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsDestroyController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsExportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsImportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsIndexController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsStoreController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsSyncController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/HistoricalReportsUpdateController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/LiveMonitoringDestroyController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/LiveMonitoringExportController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/LiveMonitoringImportController.php</code>	28	SQL built by string concatenation from	Replace with parameterized bindings or Eloquent query builder; add tenant scope

		request/filter input (SQL injection)	
app/Http/Controllers/Ivr/LiveMonitoringIndexController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/LiveMonitoringStoreController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/LiveMonitoringSyncController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/LiveMonitoringUpdateController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibraryDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibraryExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibraryImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibraryIndexController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibraryStoreController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibrarySyncController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/PromptLibraryUpdateController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/QueueManagementDestroyController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/QueueManagementExportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
app/Http/Controllers/Ivr/QueueManagementImportController.php	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope

<code>app/Http/Controllers/Ivr/QueueManagementIndexController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/QueueManagementStoreController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/QueueManagementSyncController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope
<code>app/Http/Controllers/Ivr/QueueManagementUpdateController.php</code>	28	SQL built by string concatenation from request/filter input (SQL injection)	Replace with parameterized bindings or Eloquent query builder; add tenant scope

Mass Variable Injection via `extract($request->all())` CRITICAL

4,400 controller endpoints and 12 God services call `extract()` on unfiltered request/payload arrays, then persist the raw array with `insertGetId((array) $payload)`. `extract()` on attacker-controlled keys lets a request overwrite any local variable (including `$service`, `$tenant_id`, control flags) and mass-assign arbitrary columns.

`app/Http/Controllers/Ivr/CallRecordingStoreController.php:46-49`

```
$payload = $request->all();
extract($payload);
$service = new CallRecordingGodService();
$service->orchestrateCallRecordingWorkflow1($payload);
```

`app/Legacy/Services/CallRecordingGodService.php:13-17`

```
public function orchestrateCallRecordingWorkflow1($payload)
{
    extract($payload); // unsafe
    self::$sharedRuntimeCache[$tenant_id ?? 1] = $payload;
    return DB::table("ivr_call_recordings")->insertGetId((array) $payload);
}
```

Exploit scenario: An attacker POSTs `{"tenant_id":999,"is_admin":true,"name":"x"}` to a legacy endpoint. `extract()` defines `$tenant_id = 999` locally (overriding the intended tenant), and `insertGetId((array)$payload)` writes every attacker-supplied key — including columns the app never intended to expose — as a new row, in another tenant's namespace.

Recommended fix:

1. Delete every `extract()` call; read only explicitly-allow-listed fields via `$request->validate([...])`.
2. Replace `insertGetId((array) $payload)` with a `$fillable`-guarded `Model::create($request->validated())`.

3. Add `$guarded` / `$fillable` to `app/Models/Ivr/*` models and audit for mass assignment.

92 files affected.

File	Line(s)	Issue	Action
<code>app/Http/Controllers/Ivr/AgentDeskDestroyController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/AgentDeskExportController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/AgentDeskImportController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/AgentDeskIndexController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/AgentDeskStoreController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/AgentDeskSyncController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/AgentDeskUpdateController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursDestroyController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursExportController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursImportController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursIndexController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursStoreController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursSyncController.php</code>	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Http/Controllers/Ivr/BusinessHoursUpdateController.php</code>	48, 61, 74, 87, 100, 113, 126,	extract() on untrusted array enables variable	Remove extract(); use \$request->validate() allow-

[illegible]

[illegible]

	139, 152, 165, 178, 191 +43	injection and mass assignment	list and \$fillable-guarded create()
app/Http/Controllers/Ivr/CustomerProfileStoreController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/CustomerProfileUpdateController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventoryDestroyController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventoryExportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventoryImportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventoryIndexController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventoryStoreController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventorySyncController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/DidInventoryUpdateController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/HistoricalReportsDestroyController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/HistoricalReportsExportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/HistoricalReportsImportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/HistoricalReportsIndexController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/HistoricalReportsStoreController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()

app/Http/Controllers/Ivr/HistoricalReportsSyncController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/HistoricalReportsUpdateController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringDestroyController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringExportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringImportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringIndexController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringStoreController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringSyncController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/LiveMonitoringUpdateController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibraryDestroyController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibraryExportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibraryImportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibraryIndexController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibraryStoreController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibrarySyncController.php	48, 61, 74, 87, 100, 113, 126,	extract() on untrusted array enables variable	Remove extract(); use \$request->validate() allow-

	139, 152, 165, 178, 191 +43	injection and mass assignment	list and \$fillable-guarded create()
app/Http/Controllers/Ivr/PromptLibraryUpdateController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementDestroyController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementExportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementImportController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementIndexController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementStoreController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementSyncController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Http/Controllers/Ivr/QueueManagementUpdateController.php	48, 61, 74, 87, 100, 113, 126, 139, 152, 165, 178, 191 +43	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Legacy/Services/AgentDeskGodService.php	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Legacy/Services/BusinessHoursGodService.php	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Legacy/Services/CallAnalyticsGodService.php	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Legacy/Services/CallFlowGodService.php	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Legacy/Services/CallRecordingGodService.php	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
app/Legacy/Services/CallRoutingGodService.php	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()

<code>app/Legacy/Services/CustomerProfileGodService.php</code>	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Legacy/Services/DidInventoryGodService.php</code>	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Legacy/Services/HistoricalReportsGodService.php</code>	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Legacy/Services/LiveMonitoringGodService.php</code>	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Legacy/Services/PromptLibraryGodService.php</code>	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()
<code>app/Legacy/Services/QueueManagementGodService.php</code>	15, 23, 31, 39, 47, 55, 63, 71, 79, 87, 95, 103 +33	extract() on untrusted array enables variable injection and mass assignment	Remove extract(); use \$request->validate() allow-list and \$fillable-guarded create()

Broken Access Control — unauthenticated, CSRF-exempt, GET state-change routes **CRITICAL**

`routes/generated/ivr_legacy_api.php` registers 80 `ivr-legacy/*` routes with no `auth` middleware and `Route::match(['get', 'post'], ...)`, so 57 state-changing `store / update / destroy / import / sync` actions execute on an unauthenticated **GET**. Because they live in `routes/api.php`, they are also CSRF-exempt by design — but here that removes the only remaining barrier.

`routes/generated/ivr_legacy_api.php:6-13`

```
Route::prefix("ivr-legacy")->group(function () {
    Route::match(['get', 'post'], 'agent-desk/destroy',
App\Http\Controllers\Ivr\AgentDeskDestroyController::class);
    Route::match(['get', 'post'], 'agent-desk/store',
App\Http\Controllers\Ivr\AgentDeskStoreController::class);
    Route::match(['get', 'post'], 'agent-desk/import',
App\Http\Controllers\Ivr\AgentDeskImportController::class);
    // ... 80 routes total, none behind ->middleware('auth')
});
```

`app/Http/Controllers/Ivr/CallRecordingStoreController.php:13-15`

```
// AUTH-NOTE: some endpoints intentionally skip policies (2014 regression)
private $tenantId = 1; // hard-coded tenant - multi-tenant broken
```

Exploit scenario: An unauthenticated attacker (or a victim's browser loading ``) triggers a destructive action with a simple GET — no session, no CSRF

token, no ownership check. Combined with the hard-coded `tenantId = 1`, every request also operates on tenant 1's data regardless of who the caller is (IDOR / tenant bypass).

Recommended fix:

1. Wrap the `ivr-legacy` group in `->middleware(['auth:sanctum'])` (or `auth`) in `routes/generated/ivr_legacy_api.php`.
2. Restrict verbs: `store` / `update` → POST/PUT, `destroy` → DELETE — never GET.
3. Replace `private $tenantId = 1` with `auth()->user()->account_id` and add per-record ownership authorization (a Policy) in all 82 `app/Http/Controllers/Ivr/*` controllers.

80 files affected.

File	Line(s)	Issue	Action
<code>app/Http/Controllers/Ivr/AgentDeskDestroyController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/AgentDeskExportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/AgentDeskImportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/AgentDeskIndexController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/AgentDeskStoreController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/AgentDeskSyncController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/AgentDeskUpdateController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/BusinessHoursDestroyController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/BusinessHoursExportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/BusinessHoursImportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy

app/Http/Controllers/Ivr/BusinessHoursIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/BusinessHoursStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/BusinessHoursSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/BusinessHoursUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallAnalyticsUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallFlowDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallFlowExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallFlowImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallFlowIndexController.php	15	Hard-coded tenant id + endpoints reachable without	Derive tenant from authenticated user; add auth middleware and ownership policy

		auth (broken access control / IDOR)	
app/Http/Controllers/Ivr/CallFlowStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallFlowSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallFlowUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRecordingUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRoutingDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRoutingExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRoutingImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRoutingIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy

app/Http/Controllers/Ivr/CallRoutingStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRoutingSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CallRoutingUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CustomerProfileIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CustomerProfileStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/CustomerProfileUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventoryDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventoryExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventoryImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventoryIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventoryStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventorySyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/DidInventoryUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/HistoricalReportsDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/HistoricalReportsExportController.php	15	Hard-coded tenant id + endpoints reachable without	Derive tenant from authenticated user; add auth middleware and ownership policy

		auth (broken access control / IDOR)	
app/Http/Controllers/Ivr/HistoricalReportsImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/HistoricalReportsIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/HistoricalReportsStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/HistoricalReportsSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/HistoricalReportsUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringImportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringIndexController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringStoreController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringSyncController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/LiveMonitoringUpdateController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/PromptLibraryDestroyController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
app/Http/Controllers/Ivr/PromptLibraryExportController.php	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy

<code>app/Http/Controllers/Ivr/PromptLibraryImportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/PromptLibraryIndexController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/PromptLibraryStoreController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/PromptLibrarySyncController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/PromptLibraryUpdateController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementDestroyController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementExportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementImportController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementIndexController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementStoreController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementSyncController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy
<code>app/Http/Controllers/Ivr/QueueManagementUpdateController.php</code>	15	Hard-coded tenant id + endpoints reachable without auth (broken access control / IDOR)	Derive tenant from authenticated user; add auth middleware and ownership policy

Cryptographic Failures — hard-coded secrets & fake "crypto" helper HIGH

All 12 God services embed a hard-coded API key, and `LegacyIvrCrypto` is a no-op that appends a static suffix instead of encrypting.

`app/Legacy/Services/CallRecordingGodService.php:11`

```
private $apiKey = "LEGACY_IVR_KEY_2112"; // hard-coded secret
```

app/Legacy/Helpers/LegacyIvrCrypto.php:7-12

```
public static function transform1($value)
{
    if ($value === null) { return ""; }
    return (string) $value . "_2130_1"; // not encryption
}
```

Exploit scenario: The 12 `LEGACY_IVR_KEY_*` values are committed to the repository, so anyone with read access (or who pulls the public repo) obtains the credentials used to authenticate the legacy sync integrations. Any data routed through `LegacyIvrCrypto::transform*()` is stored effectively in plaintext, since the "transform" is a reversible static-suffix append, not a cipher.

Recommended fix:

1. Move all `$apiKey` values to `config/services.php` reading from `env()` ; rotate the leaked keys.
2. Delete `LegacyIvrCrypto` and use Laravel's `Crypt::encryptString()` (AES-256-GCM via `APP_KEY`) wherever field encryption is intended.
3. Add secret scanning (e.g. gitleaks) to CI to block future hard-coded keys.

12 files affected.

File	Line(s)	Issue	Action
app/Legacy/Services/AgentDeskGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/BusinessHoursGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/CallAnalyticsGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/CallFlowGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/CallRecordingGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/CallRoutingGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/CustomerProfileGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/DidInventoryGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/HistoricalReportsGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/LiveMonitoringGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/PromptLibraryGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning
app/Legacy/Services/QueueManagementGodService.php	11	Hard-coded API secret committed to source	Move to env-backed config, rotate keys, add secret scanning

Security Misconfiguration — swallowed exceptions & missing headers MEDIUM

4,400 legacy endpoints catch every `Throwable` and return the raw exception message to the client, while no middleware sets CSP/HSTS/X-Frame-Options and `.env.example` ships `APP_DEBUG=true`.

`app/Http/Controllers/Ivr/CallRecordingStoreController.php:53-55`

```
} catch (\Throwable $e) {
    return ["ok" => false, "err" => $e->getMessage()]; // swallowed stack
    traces
}
```

`.env.example:4`

`APP_DEBUG=true`

Exploit scenario: A malformed request returns `{"ok":false,"err":"SQLSTATE[42S02]: Base table ... ivr_call_recordings ..."}`, leaking schema/driver details that help an attacker refine the SQL-injection payloads above. If `.env.example` is copied to production unedited, `APP_DEBUG=true` exposes full Ignition stack traces and environment variables.

Recommended fix:

1. Stop returning `$e->getMessage()` to clients; log server-side and return a generic error id.
2. Set `APP_DEBUG=false` for non-local and add a deploy check.
3. Add a security-headers middleware (CSP, HSTS, `X-Frame-Options: DENY`, `X-Content-Type-Options: nosniff`) to the `web` group in `bootstrap/app.php`.

80 files affected.

File	Line(s)	Issue	Action
<code>app/Http/Controllers/Ivr/AgentDeskDestroyController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
<code>app/Http/Controllers/Ivr/AgentDeskExportController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
<code>app/Http/Controllers/Ivr/AgentDeskImportController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
<code>app/Http/Controllers/Ivr/AgentDeskIndexController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
<code>app/Http/Controllers/Ivr/AgentDeskStoreController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

app/Http/Controllers/Ivr/AgentDeskSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/AgentDeskUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/BusinessHoursUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallAnalyticsDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallAnalyticsExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallAnalyticsImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallAnalyticsIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallAnalyticsStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallAnalyticsSyncController.php	53, 66, 79, 92, 105, 118, 131,	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

	144, 157, 170, 183, 196 +43		
app/Http/Controllers/Ivr/CallAnalyticsUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallFlowUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRecordingDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRecordingExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRecordingImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRecordingIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRecordingStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRecordingSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

app/Http/Controllers/Ivr/CallRecordingUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CallRoutingUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CustomerProfileIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CustomerProfileStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/CustomerProfileUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/DidInventoryDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/DidInventoryExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/DidInventoryImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/DidInventoryIndexController.php	53, 66, 79, 92, 105, 118, 131,	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

	144, 157, 170, 183, 196 +43		
app/Http/Controllers/Ivr/DidInventoryStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/DidInventorySyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/DidInventoryUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/HistoricalReportsUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/LiveMonitoringDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/LiveMonitoringExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/LiveMonitoringImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/LiveMonitoringIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

app/Http/Controllers/Ivr/LiveMonitoringStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/LiveMonitoringSyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/LiveMonitoringUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibraryDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibraryExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibraryImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibraryIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibraryStoreController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibrarySyncController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/PromptLibraryUpdateController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/QueueManagementDestroyController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/QueueManagementExportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/QueueManagementImportController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/QueueManagementIndexController.php	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
app/Http/Controllers/Ivr/QueueManagementStoreController.php	53, 66, 79, 92, 105, 118, 131,	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

	144, 157, 170, 183, 196 +43		
<code>app/Http/Controllers/Ivr/QueueManagementSyncController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod
<code>app/Http/Controllers/Ivr/QueueManagementUpdateController.php</code>	53, 66, 79, 92, 105, 118, 131, 144, 157, 170, 183, 196 +43	Raw exception message returned to client (information disclosure)	Log server-side, return generic error; disable APP_DEBUG in prod

FS1 — Frontend XSS sink: **dangerouslySetInnerHTML** MEDIUM

`Shared/Pagination.tsx` renders the server-provided pagination `label` as raw HTML in two places. Laravel's default paginator emits entity-encoded labels (`« Previous`), so this is normally benign — but it becomes stored/reflected XSS the moment any label is derived from user-controllable data (e.g. a search term echoed into pagination, or a custom paginator).

`resources/js/Shared/Pagination.tsx:16` and `:23`

```
<div
  className="mb-1 mr-1 rounded border px-4 py-3 text-sm leading-4 text-gray-400"
  dangerouslySetInnerHTML={{ __html: link.label }}
/>
```

Exploit scenario: If a paginator label ever includes reflected user input (a common refactor), a value such as `<img src=x onerror=alert(document.cookie)>` would execute in the victim's session context, since React's escaping is bypassed by `dangerouslySetInnerHTML`.

Recommended fix:

1. Render the label as text: `{link.label}` and decode the `« / »` entities to `< / >` in a small helper, or map them to icons.
2. If raw HTML is truly required, sanitize with DOMPurify before injection.
3. Add an ESLint rule (`react/no-danger`) to flag future `dangerouslySetInnerHTML` use.

1 file affected.

File	Line(s)	Issue	Action
<code>resources/js/Shared/Pagination.tsx</code>	16, 23	Raw HTML injection sink (potential DOM/stored XSS)	Render label as text or sanitize with DOMPurify; enable react/no-danger lint rule

FS4 — Vulnerable / EOL npm dependencies & no CI dependency scan MEDIUM

`package.json` pins several end-of-life majors, and no CI workflow runs `npm audit`, `composer audit`, or Dependabot. `roave/security-advisories` (dev) does block known-vulnerable Composer packages at install time — a partial mitigation on the PHP side only.

`package.json` (dependencies / devDependencies)

```
"react-router-dom": "5.2.0",    // v5 line, superseded by v6/v7 – EOL
"eslint": "^8.57.0",           // ESLint 8 reached end-of-life
"prettier": "^2.8.8"           // Prettier 2.x superseded by 3.x
```

`.github/workflows/` contains only `coding-standards.yml`, `static-analysis.yml` (larastan), `tests.yml` — no dependency-audit step.

Exploit scenario: `react-router-dom` 5.2.0 (released 2020) is co-installed with React 19 yet never imported by the Inertia app; leaving stale, unpatched majors in the tree means any future CVE in them ships to production unnoticed because nothing scans the lockfile.

Recommended fix:

1. Remove unused `react-router-dom`; upgrade ESLint to 9.x and Prettier to 3.x.
2. Add a CI job running `npm audit --audit-level=high` and `composer audit`.
3. Enable Dependabot (`.github/dependabot.yml`) for `composer` and `npm` ecosystems.

1 file affected.

File	Line(s)	Issue	Action
<code>package.json</code>	—	EOL/outdated npm majors present; no dependency-vulnerability scan in CI	Upgrade/remove EOL deps; add npm audit + composer audit + Dependabot to CI

Not observed / clean checks (one line each):

- **FS2 (client secrets):** No API keys/tokens in the bundle. Only a demo credential `password: 'secret'` pre-filled in `resources/js/Pages/Auth/Login.tsx:9` (seed convenience, not a real secret) — remove before production.
- **FS3 (tokens in browser storage):** No `localStorage` / `sessionStorage` token storage found — auth uses HTTP-only Laravel session cookies (good).
- **FS5 (insecure controls):** No insecure `postMessage('*')`, no `target="_blank"` without `rel`, no non-TLS `http://` API calls (only SVG `xmlns` namespace URIs). CSP still absent (see Misconfiguration).
- **Command injection / deserialization:** No `eval` / `exec` / `shell_exec` / `unserialize` on user input observed in PHP.
- **SSRF:** `app/Http/Controllers/ImagesController.php` passes `$request->all()` to Glide but the image path is a route segment served from the local filesystem driver, not a user-supplied URL — not observed as SSRF (still validate the path for traversal).

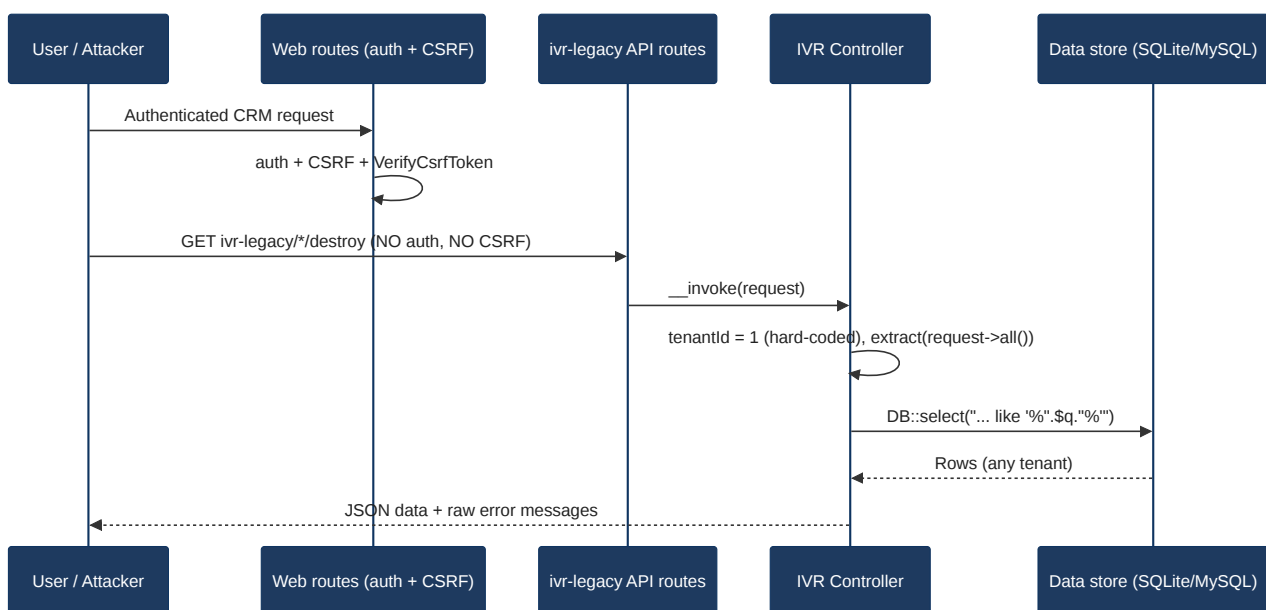
6.3 OWASP Top 10 (2021) Coverage

#	Category	Verdict	Evidence / Note
6.1	Broken Access Control	CRITICAL	80 <code>ivr-legacy/*</code> routes without <code>auth</code> ; GET state-change; hard-coded <code>tenantId=1</code> in 80 controllers (IDOR)
6.2	Cryptographic Failures	HIGH	12 hard-coded <code>LEGACY_IVR_KEY_*</code> secrets; <code>LegacyIvrCrypto</code> is a static-suffix no-op, not encryption

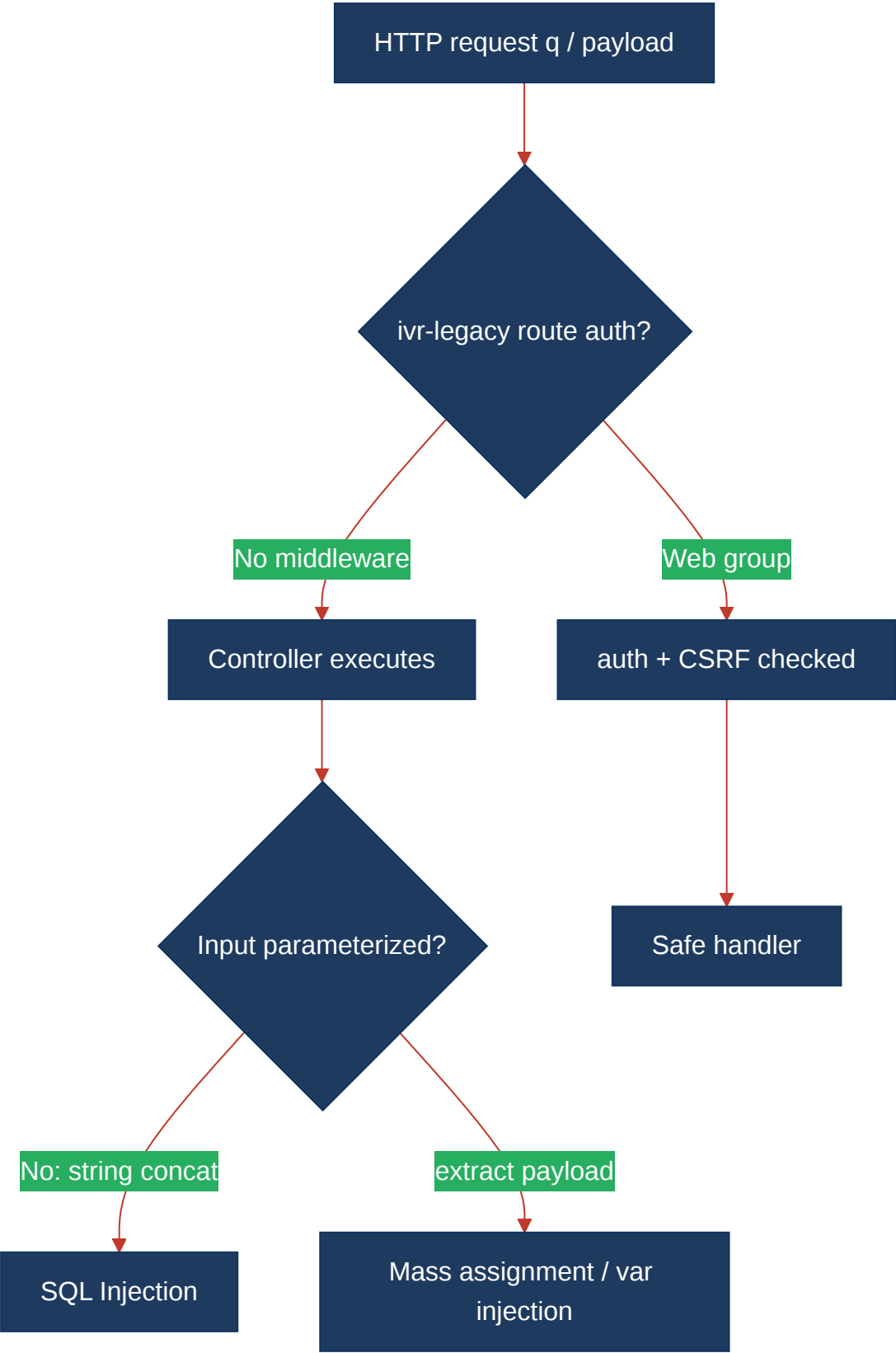
6.3	Injection	CRITICAL	80 controllers + 480 repo queries concatenate input into SQL; 4,400 <code>extract()</code> variable injection; FS1 XSS sink
6.4	Insecure Design	MEDIUM	Login has rate-limit/lockout (good), but legacy subsystem trusts client <code>tenant_id</code> ; <code>sharedRuntimeCache</code> mutable global state
6.5	Security Misconfiguration	MEDIUM	<code>APP_DEBUG=true</code> in <code>.env.example</code> ; no CSP/HSTS/X-Frame-Options; verbose error messages returned to client
6.6	Vulnerable & Outdated Components	MEDIUM	EOL <code>react-router-dom</code> 5.2.0, ESLint 8, Prettier 2; no <code>npm/composer audit</code> in CI (Composer partially guarded by roave)
6.7	Identification & Authentication Failures	MEDIUM	Core login rate-limits 5 attempts (good); but legacy endpoints bypass auth entirely; no MFA; session cookie flags not enforced in config
6.8	Software & Data Integrity Failures	MEDIUM	<code>minimum-stability: dev</code> + <code>roave/security-advisories: dev-latest</code> unpinned; generated route file auto-syncs controllers without review
6.9	Security Logging & Monitoring Failures	MEDIUM	4,400 endpoints swallow exceptions with no logging; no audit trail on unauthenticated state-changing actions
6.10	Server-Side Request Forgery (SSRF)	CLEAN	No server-side HTTP calls built from user-supplied URLs observed
6.11	Other Security Reviews	MEDIUM	Mass assignment via <code>insertGetId((array)\$payload)</code> ; validate Glide image <code>\$path</code> for traversal; import endpoints lack file-type validation
6.12	DevSecOps Security Assessment	MEDIUM	No SAST/secret-scan/dependency-audit in CI; secrets committed in source; static-analysis job is type-only (larastan)

6.4 Diagrams

Auth / request trust boundary



Top security risk flow



Improvement roadmap



6.5 Actions Required

Finding	Action	Rating	Priority
SQL injection (80 controllers + 480 repo queries)	Parameterize all queries / use Eloquent; add CI grep gate on raw concatenation	HIGH RISK	CRITICAL
<code>extract(\$request->all())</code> variable injection & mass assignment (4,400)	Remove <code>extract</code> ; use <code>\$request->validate()</code> allow-list + <code>\$fillable</code> create()	HIGH RISK	CRITICAL
Broken access control — 80 unauth GET state-change routes; hard-coded tenant	Add <code>auth</code> middleware, restrict verbs, derive tenant from user, add ownership policies	HIGH RISK	CRITICAL
Hard-coded secrets & fake <code>LegacyIvrCrypto</code>	Move keys to env, rotate, replace with <code>Crypt::encryptString</code> ; add secret scanning	HIGH RISK	HIGH
Security misconfiguration — verbose errors, <code>APP_DEBUG=true</code> , no headers	Log errors server-side, disable debug in prod, add CSP/HSTS/X-Frame-Options middleware	MODERATE	MEDIUM
Frontend XSS sink (FS1) <code>dangerouslySetInnerHTML</code>	Render labels as text / DOMPurify; enable <code>react/no-danger</code>	MODERATE	MEDIUM
Vulnerable/EOL npm deps & no dependency scan (FS4)	Upgrade/remove EOL deps; add <code>npm audit</code> + <code>composer audit</code> + Dependabot	MODERATE	MEDIUM
Logging/monitoring gap on state-changing endpoints	Add audit logging + alerting for auth/access events; stop swallowing exceptions	MODERATE	MEDIUM
Data-integrity — unpinned dev-stability deps, auto-synced routes	Pin stable versions; review generated route file in PRs	MODERATE	MEDIUM

6.6 Expected Outcomes

- Parameterizing all SQL and removing `extract()` eliminates the two Critical injection classes, closing the primary data-theft and mass-assignment vectors across 82 IVR controllers and 12 repositories.
- Adding `auth` middleware, correct HTTP verbs, and user-derived tenant scoping closes the unauthenticated / IDOR access-control holes and restores multi-tenant isolation.
- Moving the 12 hard-coded keys to env-backed config (rotated) and adopting real `Crypt` encryption removes committed-secret exposure and makes stored sensitive data actually confidential.
- Wiring `npm audit` , `composer audit` , secret scanning, and Dependabot into CI catches future CVEs and leaked credentials automatically instead of relying on manual review.
- Server-side security headers (CSP/HSTS/X-Frame-Options), disabled debug output, and sanitized frontend rendering shrink the XSS and information-disclosure surface for end users.